

Appendix C PCI DSS v4.0.1 Requirements Extract

C.1 Scope

This appendix contains PCI DSS v4.0.1 requirements and sub-requirements that NorthPay must be adhered to and included in their a written information security policy.

The appendix does not contain all of the PCI DSS requirements and it is limited to four areas, Requirements 7, 8, 10 and 12. Those four requirements contains total of 105 sub-requirements, of which 33 are not considered for this study, therefore, only 72 requirements are deemed applicable for NorthPay

Eleven of the 33 PCI DSS requirements are specifically addressed to service providers, which do not apply to a merchant, and the remaining 22 PCI DSS requirements are meant to addressed by configuring a system rather than by anything a policy can state. Therefore, this study cannot assess because it does not inspect systems or gather configuration or log output.

As outlined in Scenario Brief [Appendix A], NorthPay validates through Self-Assessment Questionnaire A-EP; therefore, they are subject to 47 requirements.

Requirement	Description	Number of requirements
7	Restrict Access to System Components and Cardholder Data by Business Need to Know	9
8	Identify Users and Authenticate Access to System Components	24
10	Log and Monitor All Access to System Components and Cardholder Data	9
12	Support Information Security with Organizational Policies and Programs	30

Table C.1: The four PCI DSS v4.0.1 requirement areas.

Requirement text extracted from PCI Security Standards Council (2024) *Payment Card Industry Data Security Standard: Requirements and Testing Procedures*, Version 4.0.1, June 2024.

C.2 Requirement 7: Restrict Access to System Components and Cardholder Data by Business Need to Know

Ref	Requirement
7.1	Processes and mechanisms for restricting access to system components and cardholder data by business need to know are defined and understood.
7.1.1	All security policies and operational procedures that are identified in Requirement 7 are: • Documented. • Kept up to date. • In use. • Known to all affected parties.
7.1.2	Roles and responsibilities for performing activities in Requirement 7 are documented, assigned, and understood.
7.2	Access to system components and data is appropriately defined and assigned.
7.2.1	An access control model is defined and includes granting access as follows: • Appropriate access depending on the entity's business and access needs. • Access to system components and data resources that is based on users' job classification and functions. • The least privileges required (for example, user, administrator) to perform a job function.
7.2.2	Access is assigned to users, including privileged users, based on: • Job classification and function. • Least privileges necessary to perform job responsibilities.
7.2.3	Required privileges are approved by authorized personnel.
7.2.4	All user accounts and related access privileges, including third-party/vendor accounts, are reviewed as follows: • At least once every six months. • To ensure user accounts and access remain appropriate

Ref	Requirement
	based on job function. • Any inappropriate access is addressed. • Management acknowledges that access remains appropriate.
7.2.5	All application and system accounts and related access privileges are assigned and managed as follows: • Based on the least privileges necessary for the operability of the system or application. • Access is limited to the systems, applications, or processes that specifically require their use.
7.2.5.1	All access by application and system accounts and related access privileges are reviewed as follows: • Periodically (at the frequency defined in the entity's targeted risk analysis, which is performed according to all elements specified in Requirement 12.3.1). • The application/system access remains appropriate for the function being performed. • Any inappropriate access is addressed. • Management acknowledges that access remains appropriate.
7.2.6	All user access to query repositories of stored cardholder data is restricted as follows: • Via applications or other programmatic methods, with access and allowed actions based on user roles and least privileges. • Only the responsible administrator(s) can directly access or query repositories of stored CHD.

Table C.2: Requirement 7, the sub-requirements for NorthPay.

C.3 Requirement 8: Identify Users and Authenticate Access to System Components

Ref	Requirement
8.1	Processes and mechanisms for identifying users and authenticating access to system components are

Ref	Requirement
	defined and understood.
8.1.1	All security policies and operational procedures that are identified in Requirement 8 are: • Documented. • Kept up to date. • In use. • Known to all affected parties.
8.1.2	Roles and responsibilities for performing activities in Requirement 8 are documented, assigned, and understood.
8.2	User identification and related accounts for users and administrators are strictly managed throughout an account's lifecycle.
8.2.1	All users are assigned a unique ID before access to system components or cardholder data is allowed.
8.2.2	Group, shared, or generic IDs, or other shared authentication credentials are only used when necessary on an exception basis, and are managed as follows: • ID use is prevented unless needed for an exceptional circumstance. • Use is limited to the time needed for the exceptional circumstance. • Business justification for use is documented. • Use is explicitly approved by management. • Individual user identity is confirmed before access to an account is granted. • Every action taken is attributable to an individual user.
8.2.4	Addition, deletion, and modification of user IDs, authentication factors, and other identifier objects are managed as follows: • Authorized with the appropriate approval. • Implemented with only the privileges specified on the documented approval.
8.2.5	Access for terminated users is immediately revoked.

Ref	Requirement
8.2.6	Inactive user accounts are removed or disabled within 90 days of inactivity.
8.2.7	Accounts used by third parties to access, support, or maintain system components via remote access are managed as follows: • Enabled only during the time period needed and disabled when not in use. • Use is monitored for unexpected activity.
8.2.8	If a user session has been idle for more than 15 minutes, the user is required to re-authenticate to re-activate the terminal or session.
8.3	Strong authentication for users and administrators is established and managed.
8.3.1	All user access to system components for users and administrators is authenticated via at least one of the following authentication factors: • Something you know, such as a password or passphrase. • Something you have, such as a token device or smart card. • Something you are, such as a biometric element.
8.3.3	User identity is verified before modifying any authentication factor.
8.3.4	Invalid authentication attempts are limited by: • Locking out the user ID after not more than 10 attempts. • Setting the lockout duration to a minimum of 30 minutes or until the user's identity is confirmed.
8.3.5	If passwords/passphrases are used as authentication factors to meet Requirement 8.3.1, they are set and reset for each user as follows: • Set to a unique value for first-time use and upon reset. • Forced to be changed immediately after the first use.
8.3.6	If passwords/passphrases are used as authentication factors to meet Requirement 8.3.1, they meet the following minimum level of complexity:

Ref	Requirement
	• A minimum length of 12 characters (or IF the system does not support 12 characters, a minimum length of eight characters). • Contain both numeric and alphabetic characters.
8.3.7	Individuals are not allowed to submit a new password/passphrase that is the same as any of the last four passwords/passphrases used.
8.3.8	Authentication policies and procedures are documented and communicated to all users including: • Guidance on selecting strong authentication factors. • Guidance for how users should protect their authentication factors. • Instructions not to reuse previously used passwords/passphrases. • Instructions to change passwords/passphrases if there is any suspicion or knowledge that the password/passphrases have been compromised and how to report the incident.
8.3.9	If passwords/passphrases are used as the only authentication factor for user access (i.e., in any single-factor authentication implementation) then either: • Passwords/passphrases are changed at least once every 90 days, OR • The security posture of accounts is dynamically analyzed, and real-time access to resources is automatically determined accordingly.
8.3.11	Where authentication factors such as physical or logical security tokens, smart cards, or certificates are used: • Factors are assigned to an individual user and not shared among multiple users. • Physical and/or logical controls ensure only the intended user can use that factor to gain access.
8.4	Multi-factor authentication (MFA) is implemented to secure access into the CDE.

Ref	Requirement
8.4.1	MFA is implemented for all non-console access into the CDE for personnel with administrative access.
8.4.2	MFA is implemented for all non-console access into the CDE.
8.4.3	MFA is implemented for all remote access originating from outside the entity's network that could access or impact the CDE.
8.6	Use of application and system accounts and associated authentication factors is strictly managed.
8.6.1	If accounts used by systems or applications can be used for interactive login, they are managed as follows: • Interactive use is prevented unless needed for an exceptional circumstance. • Interactive use is limited to the time needed for the exceptional circumstance. • Business justification for interactive use is documented. • Interactive use is explicitly approved by management. • Individual user identity is confirmed before access to account is granted. • Every action taken is attributable to an individual user.
8.6.2	Passwords/passphrases for any application and system accounts that can be used for interactive login are not hard coded in scripts, configuration/property files, or bespoke and custom source code.
8.6.3	Passwords/passphrases for any application and system accounts are protected against misuse as follows: • Passwords/passphrases are changed periodically (at the frequency defined in the entity's targeted risk analysis, which is performed according to all elements specified in Requirement 12.3.1) and upon suspicion or confirmation of compromise. • Passwords/passphrases are constructed with sufficient complexity appropriate for how frequently the entity changes the passwords/passphrases.

Table C.3: Requirement 8, the sub-requirements for NorthPay.

C.4 Requirement 10: Log and Monitor All Access to System Components and Cardholder Data

Ref	Requirement
10.1	Processes and mechanisms for logging and monitoring all access to system components and cardholder data are defined and understood.
10.1.1	All security policies and operational procedures that are identified in Requirement 10 are: • Documented. • Kept up to date. • In use. • Known to all affected parties.
10.1.2	Roles and responsibilities for performing activities in Requirement 10 are documented, assigned, and understood.
10.3	Audit logs are protected from destruction and unauthorized modifications.
10.3.1	Read access to audit logs files is limited to those with a job-related need.
10.4	Audit logs are reviewed to identify anomalies or suspicious activity.
10.4.1	The following audit logs are reviewed at least once daily: • All security events. • Logs of all system components that store, process, or transmit CHD and/or SAD. • Logs of all critical system components. • Logs of all servers and system components that perform security functions (for example, network security controls, intrusion-detection systems/intrusion-prevention systems (IDS/IPS), authentication servers).
10.4.2	Logs of all other system components (those not specified in Requirement 10.4.1) are reviewed periodically.
10.4.2.1	The frequency of periodic log reviews for all other system

Ref	Requirement
	components (not defined in Requirement 10.4.1) is defined in the entity's targeted risk analysis, which is performed according to all elements specified in Requirement 12.3.1.
10.4.3	Exceptions and anomalies identified during the review process are addressed.
10.5	Audit log history is retained and available for analysis.
10.5.1	Retain audit log history for at least 12 months, with at least the most recent three months immediately available for analysis.
10.7	Failures of critical security control systems are detected, reported, and responded to promptly.
10.7.3	Failures of any critical security control systems are responded to promptly, including but not limited to: • Restoring security functions. • Identifying and documenting the duration (date and time from start to end) of the security failure. • Identifying and documenting the cause(s) of failure and documenting required remediation. • Identifying and addressing any security issues that arose during the failure. • Determining whether further actions are required as a result of the security failure. • Implementing controls to prevent the cause of failure from reoccurring. • Resuming monitoring of security controls.

Table C.4: Requirement 10, the sub-requirements for NorthPay.

C.5 Requirement 12: Support Information Security with Organizational Policies and Programs

Ref	Requirement
12.1	A comprehensive information security policy that governs and provides direction for protection of the

Ref	Requirement
	entity's information assets is known and current.
12.1.1	An overall information security policy is: • Established. • Published. • Maintained. • Disseminated to all relevant personnel, as well as to relevant vendors and business partners.
12.1.2	The information security policy is: • Reviewed at least once every 12 months. • Updated as needed to reflect changes to business objectives or risks to the environment.
12.1.3	The security policy clearly defines information security roles and responsibilities for all personnel, and all personnel are aware of and acknowledge their information security responsibilities.
12.1.4	Responsibility for information security is formally assigned to a Chief Information Security Officer or other information security knowledgeable member of executive management.
12.2	Acceptable use policies for end-user technologies are defined and implemented.
12.2.1	Acceptable use policies for end-user technologies are documented and implemented, including: • Explicit approval by authorized parties. • Acceptable uses of the technology. • List of products approved by the company for employee use, including hardware and software.
12.3	Risks to the cardholder data environment are formally identified, evaluated, and managed.
12.3.1	For each PCI DSS requirement that specifies completion of a targeted risk analysis, the analysis is documented and includes: • Identification of the assets being protected. • Identification of the threat(s) that the requirement is

Ref	Requirement
	protecting against. • Identification of factors that contribute to the likelihood and/or impact of a threat being realized. • Resulting analysis that determines, and includes justification for, how the frequency or processes defined by the entity to meet the requirement minimize the likelihood and/or impact of the threat being realized. • Review of each targeted risk analysis at least once every 12 months to determine whether the results are still valid or if an updated risk analysis is needed. • Performance of updated risk analyses when needed, as determined by the annual review.
12.3.2	A targeted risk analysis is performed for each PCI DSS requirement that the entity meets with the customized approach, to include: • Documented evidence detailing each element specified in Appendix D: Customized Approach (including, at a minimum, a controls matrix and risk analysis). • Approval of documented evidence by senior management. • Performance of the targeted analysis of risk at least once every 12 months.
12.3.3	Cryptographic cipher suites and protocols in use are documented and reviewed at least once every 12 months, including at least the following: • An up-to-date inventory of all cryptographic cipher suites and protocols in use, including purpose and where used. • Active monitoring of industry trends regarding continued viability of all cryptographic cipher suites and protocols in use. • Documentation of a plan, to respond to anticipated changes in cryptographic vulnerabilities.
12.3.4	Hardware and software technologies in use are reviewed at least once every 12 months, including at least the following: • Analysis that the technologies continue to receive security

Ref	Requirement
	fixes from vendors promptly. • Analysis that the technologies continue to support (and do not preclude) the entity's PCI DSS compliance. • Documentation of any industry announcements or trends related to a technology, such as when a vendor has announced "end of life" plans for a technology. • Documentation of a plan, approved by senior management, to remediate outdated technologies, including those for which vendors have announced "end of life" plans.
12.5	PCI DSS scope is documented and validated.
12.5.1	An inventory of system components that are in scope for PCI DSS, including a description of function/use, is maintained and kept current.
12.5.2	PCI DSS scope is documented and confirmed by the entity at least once every 12 months and upon significant change to the in-scope environment. At a minimum, the scoping validation includes: • Identifying all data flows for the various payment stages (for example, authorization, capture settlement, chargebacks, and refunds) and acceptance channels (for example, card-present, card-not-present, and e-commerce). • Updating all data-flow diagrams per Requirement 1.2.4. • Identifying all locations where account data is stored, processed, and transmitted, including but not limited to: 1) any locations outside of the currently defined CDE, 2) applications that process CHD, 3) transmissions between systems and networks, and 4) file backups. • Identifying all system components in the CDE, connected to the CDE, or that could impact security of the CDE. • Identifying all segmentation controls in use and the environment(s) from which the CDE is segmented, including justification for environments being out of scope. • Identifying all connections from third-party entities with

Ref	Requirement
	access to the CDE. • Confirming that all identified data flows, account data, system components, segmentation controls, and connections from third parties with access to the CDE are included in scope.
12.6	Security awareness education is an ongoing activity.
12.6.1	A formal security awareness program is implemented to make all personnel aware of the entity's information security policy and procedures, and their role in protecting the cardholder data.
12.6.2	The security awareness program is: • Reviewed at least once every 12 months, and • Updated as needed to address any new threats and vulnerabilities that may impact the security of the entity's cardholder data and/or sensitive authentication data, or the information provided to personnel about their role in protecting cardholder data.
12.6.3	Personnel receive security awareness training as follows: • Upon hire and at least once every 12 months. • Multiple methods of communication are used. • Personnel acknowledge at least once every 12 months that they have read and understood the information security policy and procedures.
12.6.3.1	Security awareness training includes awareness of threats and vulnerabilities that could impact the security of cardholder data and/or sensitive authentication data, including but not limited to: • Phishing and related attacks. • Social engineering.
12.6.3.2	Security awareness training includes awareness about the acceptable use of end-user technologies in accordance with Requirement 12.2.1.
12.7	Personnel are screened to reduce risks from insider

Ref	Requirement
	threats.
12.7.1	Potential personnel who will have access to the CDE are screened, within the constraints of local laws, prior to hire to minimize the risk of attacks from internal sources.
12.8	Risk to information assets associated with third-party service provider (TPSP) relationships is managed.
12.8.1	A list of all third-party service providers (TPSPs) with which account data is shared or that could affect the security of account data is maintained, including a description for each of the services provided.
12.8.2	Written agreements with TPSPs are maintained as follows: • Written agreements are maintained with all TPSPs with which account data is shared or that could affect the security of the CDE. • Written agreements include acknowledgments from TPSPs that TPSPs are responsible for the security of account data the TPSPs possess or otherwise store, process, or transmit on behalf of the entity, or to the extent that the TPSP could impact the security of the entity's cardholder data and/or sensitive authentication data.
12.8.3	An established process is implemented for engaging TPSPs, including proper due diligence prior to engagement.
12.8.4	A program is implemented to monitor TPSPs' PCI DSS compliance status at least once every 12 months.
12.8.5	Information is maintained about which PCI DSS requirements are managed by each TPSP, which are managed by the entity, and any that are shared between the TPSP and the entity.
12.10	Suspected and confirmed security incidents that could impact the CDE are responded to immediately.
12.10.1	An incident response plan exists and is ready to be activated in the event of a suspected or confirmed security incident. The plan includes, but is not limited to:

Ref	Requirement
	• Roles, responsibilities, and communication and contact strategies in the event of a suspected or confirmed security incident, including notification of payment brands and acquirers, at a minimum. • Incident response procedures with specific containment and mitigation activities for different types of incidents. • Business recovery and continuity procedures. • Data backup processes. • Analysis of legal requirements for reporting compromises. • Coverage and responses of all critical system components. • Reference or inclusion of incident response procedures from the payment brands.
12.10.2	At least once every 12 months, the security incident response plan is: • Reviewed and the content is updated as needed. • Tested, including all elements listed in Requirement 12.10.1.
12.10.3	Specific personnel are designated to be available on a 24/7 basis to respond to suspected or confirmed security incidents.
12.10.4	Personnel responsible for responding to suspected and confirmed security incidents are appropriately and periodically trained on their incident response responsibilities.
12.10.4.1	The frequency of periodic training for incident response personnel is defined in the entity's targeted risk analysis, which is performed according to all elements specified in Requirement 12.3.1.
12.10.5	The security incident response plan includes monitoring and responding to alerts from security monitoring systems, including but not limited to: • Intrusion-detection and intrusion-prevention systems. • Network security controls.

Ref	Requirement
	• Change-detection mechanisms for critical files. • The change-and tamper-detection mechanism for payment pages. This bullet is a best practice until its effective date; refer to Applicability Notes below for details. • Detection of unauthorized wireless access points.
12.10.6	The security incident response plan is modified and evolved according to lessons learned and to incorporate industry developments.
12.10.7	Incident response procedures are in place, to be initiated upon the detection of stored PAN anywhere it is not expected, and include: • Determining what to do if PAN is discovered outside the CDE, including its retrieval, secure deletion, and/or migration into the currently defined CDE, as applicable. • Identifying whether sensitive authentication data is stored with PAN. • Determining where the account data came from and how it ended up where it was not expected. • Remediating data leaks or process gaps that resulted in the account data being where it was not expected.

Table C.5: Requirement 12, the sub-requirements for NorthPay